

SOC Level 1 Investigation Report

Spooky Sweets Candy Company Cyber Incident

Overview

Investigation Type: Phishing / Malware / Credential Theft / Lateral Movement / Data Staging

Role: SOC Level 1 Analyst

Environment: Spooky Sweets Candy Company

Platform: KC7 Cyber Range

Investigation Date: July 29, 2026

Executive Summary

Spooky Sweets Candy Company experienced a coordinated cyber intrusion involving:

- Phishing campaigns targeting employees
- Malicious email attachments and links
- Malware deployment
- Credential dumping
- Internal reconnaissance
- Lateral movement
- Data staging
- Cryptomining activity

The attackers, identified as The Witch's Coven, gained initial access through phishing emails impersonating external communications. After compromising employee systems, the threat actors deployed Mimikatz, 7-Zip, and XMRig cryptocurrency miner.

MITRE ATT&CK techniques identified:

- Phishing (T1566)
- User Execution
- Credential Dumping (T1003)
- System Discovery
- Archive Collected Data (T1560)
- Data Staged (T1074)
- Resource Hijacking (T1496)

Incident Timeline

Phase 1 — Initial Reconnaissance

Malicious domains identified:

- halloween-fall.com — 192.37.102.174
- halloween-infrastructure.com — 17.10.87.161
- spooky-fall.com — 141.107.162.16

Phase 2 — Phishing Campaign

Example subjects:

- [EXTERNAL] Trick or Treat: Pumpkin Patch Pirates has sent you a message.
- [EXTERNAL] Your facility is closing on October 31.

Attacker emails:

- boo.boo@hotmail.com
- booiknowwhatyoudid@yandex.com

Phase 3 — Wallpaper Malware Campaign

Malicious files:

- spooky.png
- trickortreat.png

Affected hosts: 839 systems

SHA256:

c27383277bf017f56b4d5b7b11419b09230b264fb40b0c42311c59f4c596a5f8

Actual hash:

499d342120bad21b637a1aa2bb54ac35e2bb5e3f2dd298dbf6fa3c398fc03fad

Original filename:

wallpaper pumpkin actor.jpg

Phase 4 — Persistence and Execution

Wallpaper modification command:

```
reg add "HKEY_CURRENT_USER\\Control Panel\\Desktop" /v Wallpaper /t REG_SZ /d  
C:\\Users\\Public\\Pictures\\spooky.png /f
```

MITRE:

Modify Registry — T1112

Phase 5 — Credential Theft

Tool:

mimikatz.exe

Command:

mimikatz.exe "sekurlsa::logonpasswords"

Affected users:

26

MITRE:

OS Credential Dumping — T1003

LSASS Memory — T1003.001

Phase 6 — Internal Reconnaissance

Commands:

net view /all /domain

sc query

Purpose:

- Enumerate domain computers
- Discover services
- Identify lateral movement targets

Phase 7 — Malware Deployment

File:

controller.exe

Location:

C:\\ProgramData\\controller.exe

Example delivery IPs:

- 196.2.219.94
- 206.102.244.26

Phase 8 — Data Collection and Staging

Tool:

7z2002-x64.exe

Archives:

- documents.7z
- tunes-but-recipes.7z

Locations:

- C:\\Users\\Public\\Documents\\documents.7z
- C:\\Users\\Public\\Music\\tunes-but-recipes.7z

MITRE:

Archive Collected Data — T1560

Data Staged — T1074

Phase 9 — Cryptomining Activity

Tool:

Runner.exe

Identified as:

XMRig

Command:

Runner.exe -a cryptonight-heavy --url=witchs.coven.rocks:666

MITRE:

Resource Hijacking — T1496

Attribution

Decoded message:

Hacked by the Witch's Coven

Threat Actor:

The Witch's Coven

Indicators of Compromise

Domains:

- halloween-fall.com
- halloween-infrastructure.com
- spooky-fall.com
- regulations-compliance.com
- health-compliance.com
- safetyregulations.com

Files:

- spooky.png — Malware delivery / wallpaper modification
- trickortreat.png — Malicious image payload
- controller.exe — Implant downloader
- mimikatz.exe — Credential dumping
- 7z2002-x64.exe — Data compression
- Runner.exe — Cryptomining

SOC L1 Detection Opportunities

Email Monitoring:

- Detect suspicious external links
- Detect phishing subjects
- Monitor suspicious sender domains

Endpoint Monitoring:

- Alert on mimikatz.exe
- Detect sekurlsa::logonpasswords
- Monitor discovery commands
- Detect suspicious PowerShell

File Monitoring:

Monitor:

- C:\\ProgramData
- C:\\Users\\Public
- C:\\Windows\\Temp

Response Actions

Immediate:

- Isolate infected endpoints
- Reset compromised credentials
- Block malicious domains
- Remove unauthorized tools
- Search for IOC matches

Short-Term:

- Improve email filtering
- Block executable attachments
- Improve endpoint detection rules
- Monitor privileged accounts

Long-Term:

- Conduct phishing awareness training
- Implement MFA
- Deploy behavioral detection
- Perform red-team exercises

Analyst Skills Demonstrated

- Email Investigation
- Threat Hunting
- KQL Query Development
- Malware Analysis
- IOC Extraction
- MITRE ATT&CK Mapping
- Endpoint Investigation
- Incident Documentation

Final Assessment

The Spooky Sweets incident represents a complete intrusion lifecycle:

Phishing → Execution → Persistence → Credential Theft → Discovery → Lateral Movement → Data Staging → Cryptomining

A SOC Level 1 analyst successfully identified attacker behavior, extracted indicators, mapped techniques to MITRE ATT&CK, and provided actionable defensive recommendations.